INFORMATION SECURITY & DATA SECURITY

Quick Revision Cheat Sheet | Simple Words, Exam-Ready

1. What Is Information Security?

Information Security (InfoSec) means keeping important information safe from people who should not see, change, use, or destroy it. The goal is simple: only the right people can access the right data. This covers financial data, business secrets, personal data, and information stored on paper, on computers, or even spoken aloud.

2. Types of Security

Type	What It Covers
Information Security	Broadest term. Covers all information: paper, digital, hardware, software.
IT Security	Protects physical and digital tech (servers, data centers). Not paper files.
Cybersecurity	Part of InfoSec. Only computers, networks, software, digital data.
Data Security	Protects digital data across its whole life: hardware, software, policy.

3. CIA Triad & Core Concepts (Most Important)

Term	Meaning (Simple)	Easy Example
Confidentiality	Only allowed people can see the data.	A student cannot see another student's grades.
Integrity	Data stays correct; no one changes it without permission.	A bank balance changes only for real transactions.
Availability	Right users can get data whenever they need it.	Hospital records must be reachable 24/7.
Nonrepudiation	A person cannot deny an action they really did.	A manager cannot deny approving a transfer (signature + timestamp proof).
Authentication	Checking that a user really is who they claim to be.	Login with password + phone OTP code.
Information Assurance	Ongoing effort to keep C-I-A working at all times.	Not a one-time task — a continuous process.

Note: NIST first proposed the CIA Triad in 1977. Users are grouped as Privileged (most access), Limited (only work-related data), and Public (open data).

4. Information Security Program — Key Parts

Part	Simple Meaning + Example
Risk Management	Find and manage risks. Example: regular vulnerability checks.
Security Policies	Written rules. Example: password policy, acceptable use policy.
Access Control	Only right users reach data. Example: Role-Based Access Control (RBAC).
Authentication & Authorization	Verify identity, then give correct access level. Example: 2FA.
Incident Response Plan	Steps for when a breach happens. Example: ransomware procedure.
Security Awareness Training	Teach staff about threats. Example: yearly phishing training.
Data Encryption & Protection	Make data unreadable to outsiders. Example: encrypt customer database.
Monitoring & Auditing	Watch systems and logs for anything unusual.
Compliance & Legal	Follow laws/standards. Example: GDPR, ISO/IEC 27001.

5. Risk Assessment — 6 Simple Steps

Step	What To Do
1. Identify Assets	List important items: customer data, servers, software.
2. Identify Threats	List possible dangers: malware, insider threats, disasters.
3. Identify Vulnerabilities	Find weak points: unpatched systems, untrained staff.
4. Assess Impact & Likelihood	Rate how bad and how likely each risk is.
5. Determine Risk Level	Use a risk matrix: Low, Medium, or High.
6. Recommend Controls	Suggest fixes: firewalls, training, backups.

Threats = things that can cause harm (cyber or physical). **Vulnerabilities** = weak points an attacker can use (bugs, wrong settings, human mistakes).

6. Incident Response Plan (IRP) — Quick Steps

Made by the CSIRT (Computer Security Incident Response Team). Steps: 1) Gather the security team 2) Verify the threat source 3) Contain and stop the threat fast 4) Check the damage caused 5) Notify the right people inside and outside the organization.

7. Common Security Tools

Tool	Purpose	Example
Antivirus / Anti-malware	Finds and removes malicious programs.	Windows Defender, Bitdefender
Firewall	Controls network traffic by rules.	pfSense, Cisco ASA
IDS / IPS	Detects (IDS) or blocks (IPS) unauthorized access.	Snort, Suricata
Encryption Tools	Turns data into unreadable code.	VeraCrypt, BitLocker
Password Manager	Stores and creates strong passwords.	LastPass, Bitwarden
VPN	Makes a secure encrypted tunnel online.	NordVPN, OpenVPN
SIEM	Collects and studies security logs.	Splunk, IBM QRadar
MFA	Needs more than one identity check.	Google Authenticator

8. Techniques To Build Security

Technique	What It Does
Access Control	Limits access based on user role.
Data Backup & Recovery	Keeps copies of data to restore after loss.
Patch Management	Keeps software updated to fix known bugs.
Security Awareness Training	Teaches staff to spot threats like phishing.
Penetration Testing	Ethical hacker tests the system before real attackers do.
Network Segmentation	Splits network into smaller parts to limit damage.
Audit & Monitoring	Keeps checking logs for strange activity.

9. Common Threats

Threat	Simple Meaning
Cyberattacks	Malware, phishing, ransomware, DDoS, APT — steal or damage data.
Employee Error	Lost devices, clicking bad links, weak passwords.
Weak Endpoint Security	Device without antivirus becomes an entry point.
Malicious Insiders	Staff who intentionally cause harm for personal gain.

Threat	Simple Meaning
Negligent Insiders	Staff who accidentally break the rules.
Misconfigurations	Wrong setup of cloud, software, or apps creates gaps.
Social Engineering	Tricks people into giving away passwords (fake calls/emails).

10. Benefits vs Challenges

Benefits	Challenges
Business continuity — recover data fast	Complacency — teams relax after setup
Compliance — follow HIPAA, PCI-DSS	Complexity — IoT and mobile add difficulty
Cost savings — avoid expensive breaches	Time drain — constant maintenance needed
Greater efficiency — clear, secure process	Global connections — different country rules
Reputation protection — keeps customer trust	Inflexibility — too much security blocks work
Risk reduction — fewer, smaller attacks	Third-party risk — vendors add new gaps

11. Data Security — Meaning & Types

Data Security protects digital information from unauthorized access, corruption, or theft, across its whole life. It is one part of the bigger Information Security field.

Type	Simple Meaning
Encryption	Turns readable data into unreadable code. Only the right key can open it.
Data Erasure	Fully overwrites data so it cannot be recovered (safer than delete).
Data Masking	Hides real data with fake data for safe testing.
Data Resiliency	Ability to recover from failures with little data loss.

12. Data Security Strategy — People, Process, Tech

Area	Simple Meaning
Physical Security	Protect server rooms; fire and climate control.
Access Management	Give access only to those who truly need it (least privilege).
Application Security	Always update software with the newest patches.
Backups	Keep tested backup copies; protect them like main data.
Employee Education	Train staff on passwords and social engineering.
Network & Endpoint Security	Use detection and response tools everywhere, on-site and cloud.

13. Bangladesh Context (Data Security)

Bangladesh is going through fast digital growth. Key points: growing data volume, mixed local + cloud systems, more aware customers, and rules under the **Digital Security Act (DSA) 2018**, Bangladesh Bank, and BTRC. Not following these rules can bring fines and reputation loss. Trends to know: AI for fast threat detection (banking/telecom/e-commerce), multicloud security, and future-ready quantum-safe encryption.

14. Famous Security Breaches

Incident	What Was Leaked	Main Result
Equifax (2017)	147M SSNs, birth dates, addresses	$700M+ fines; patch focus grew
Yahoo (2013-14)	All 3B accounts: names, emails, passwords	$350M price cut; trust lost
Target (2013)	40M cards; 70M customer records	$162M cost; vendor risk exposed

Incident	What Was Leaked	Main Result
Bangladesh Bank (2016)	$81M stolen via SWIFT fraud	Global SWIFT security review
Sony Pictures (2014)	Films, emails, business data	Big financial + reputation loss
Cambridge Analytica (2018)	87M Facebook profiles, no consent	$5B FTC fine; GDPR push
Facebook DB Leak (2019)	Phone numbers, names, IDs	SIM-swap/phishing risk rose
Google+ Exposure (2018)	500K+ accounts' personal info	Google+ shut down early

Key Lesson: Most breaches happen due to unpatched software, weak passwords, third-party gaps, or poor access control. Be proactive, not reactive.